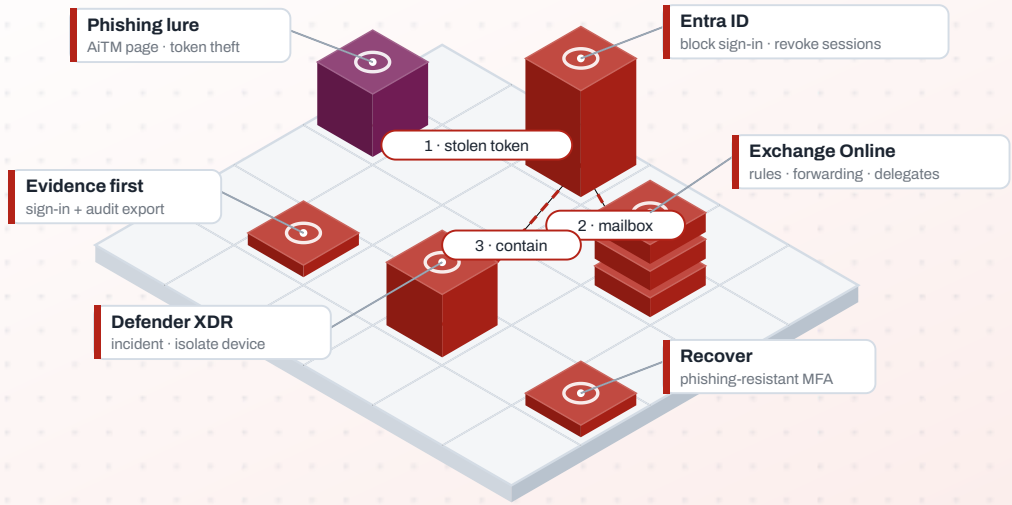
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-SEC-002

Containing a Compromised Microsoft 365 Account

Respond to business email compromise and account takeover in Entra ID and Exchange Online: triage the alert, preserve evidence first, contain in a fixed order (sign-in, sessions, credentials, mailbox, apps, device), then investigate scope, recover the user on phishing-resistant MFA and close with lessons learned.

Security Operations | Incident Response | Exchange Online



DOCUMENT ID	SOP-SEC-002
VERSION	1.0
EFFECTIVE	October 2026
AUDIENCE	SOC analysts, identity and M365 administrators, incident managers, auditors (Chapters 4 and 8)
AUTHOR	Richmond Dieujuste, Principal Consultant

Contents

1. Concepts You Need First 3
1.1 What an attacker does after takeover 3
1.2 Sessions, tokens and why revocation matters 4
1.3 The incident response lifecycle 5
1.4 Severity 5

2. Access, Prerequisites and Planning 7
2.1 Level of access required 7
2.2 Licensing and data you need 7
2.3 Prerequisites checklist 8
2.4 Risk and planning notes 8

3. Detect and Triage 9
3.1 Detection sources 9

4. Preserve Evidence First 11
4.1 Connect 11
4.2 Export mailbox configuration 12
4.3 Export identity evidence 12

5. Contain 13

6. Investigate and Scope 16
6.1 Build the timeline 16
6.2 Query the Unified Audit Log 16
6.3 Hunting queries 17

7. Eradicate, Recover and Communicate 18
7.1 Eradication checklist 18
7.2 Communication and escalation 18
7.3 Lessons learned 19

8. Verification, Rollback and Troubleshooting 20
8.1 Verification checklist 20
8.2 Rollback 20
8.3 Troubleshooting 21

9. Summary, Glossary and Review 22
9.1 Chapter summary 22
9.2 Glossary 22
9.3 Framework references 23

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain what an attacker does after taking over a mailbox, and why a password reset alone does not end the incident.
- Triage a risky-user, impossible-travel or user-reported alert and assign a severity within 15 minutes.
- Preserve sign-in, audit and mailbox evidence before any containment step changes it.
- Contain an account in the fixed order: block sign-in, revoke sessions, reset credentials, clean MFA methods, inbox rules, forwarding, delegates and OAuth grants, isolate devices.
- Scope the incident with the Unified Audit Log and KQL, then recover the user and record lessons learned.

Time	Difficulty	Minimum access	Risk
30–60 min to contain · days to close	Intermediate to advanced	Security Operator + Exchange Recipient Admin	High if evidence is destroyed or containment is partial

CHAPTER 1

Concepts You Need First

A **compromised account** is a user identity that someone other than the user can sign in as. In Microsoft 365 the usual goal is the mailbox: read mail, learn who pays whom, then send a convincing request to change bank details or approve a payment. This is **business email compromise (BEC)**. The procedure in this SOP is built around one fact: by the time anyone notices, the attacker has usually set something up that survives a password reset.

KEY CONCEPT · THE PASSWORD IS NOT THE INCIDENT

Modern phishing kits sit between the user and the real sign-in page (*adversary-in-the-middle*). They relay the password and the MFA approval, then keep the **session cookie and tokens** that Entra ID issues. With those, the attacker never needs the password again. A reset changes nothing they are using unless sessions are also revoked and the persistence they created (rules, forwarding, app consents, new MFA methods) is removed.

1.1 What an attacker does after takeover

The pattern is consistent enough to drive a checklist. Each stage leaves a trace in a different log, and each needs its own containment step.

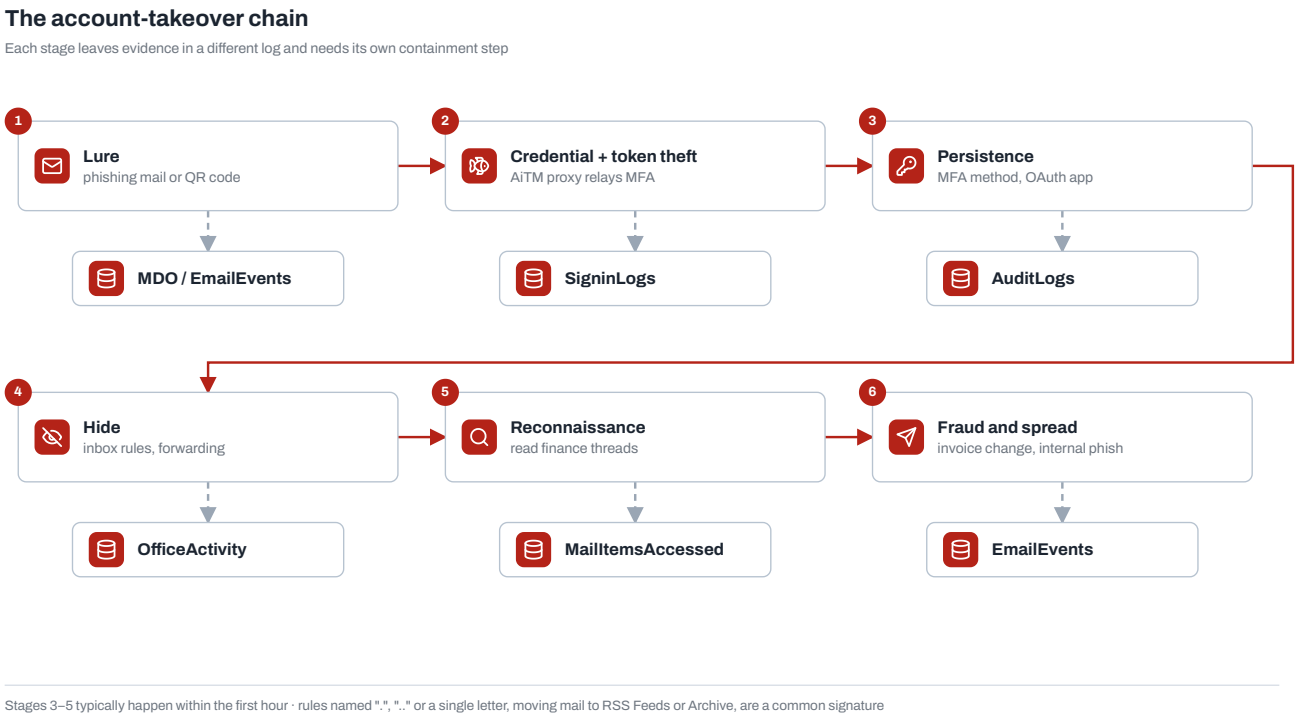


Figure 1. Six stages, six evidence sources. The containment order in Chapter 5 removes them in reverse of their value to the attacker.

1.2 Sessions, tokens and why revocation matters

After a successful sign-in, Entra ID issues a **refresh token** (long-lived, used to obtain new access tokens) and the app receives an **access token** (typically valid for about an hour). Browsers also hold a session cookie for Entra ID. Blocking sign-in and resetting the password stop *new* interactive sign-ins; revoking sessions invalidates the refresh tokens and session cookies so the stolen ones cannot mint new access tokens.

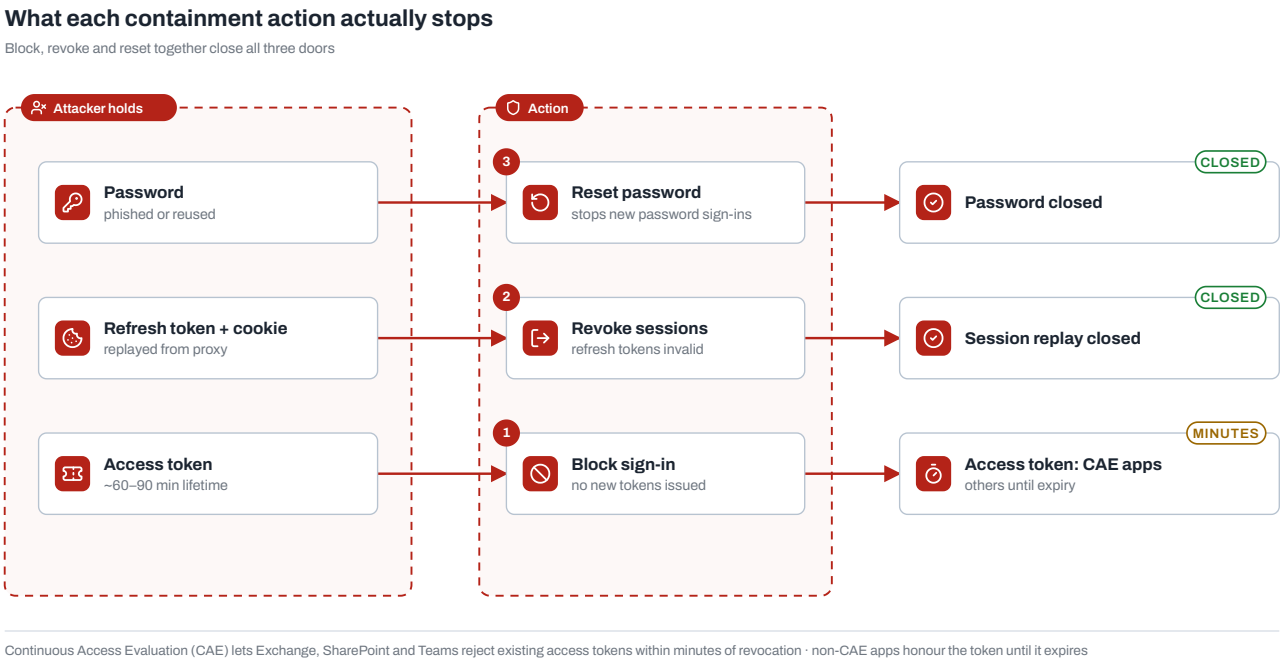


Figure 2. Why the three identity actions belong together. Any one on its own leaves the attacker a way back in.

1.3 The incident response lifecycle

NIST SP 800-61 Revision 3 (2025) aligns incident response with the CSF 2.0 functions, but the working loop inside an incident is unchanged: **detect and analyse, contain, eradicate, recover**, then improve. This SOP follows that loop with one addition that matters for audits and for any later legal question: **preserve evidence before containment changes it**.

Phase	Question it answers	Chapter
Detect and triage	Is this real, whose account, how bad?	3
Preserve	What do we need to keep before we touch anything?	4
Contain	How do we stop the attacker using this account right now?	5
Investigate and scope	What did they do, and who else is affected?	6
Eradicate and recover	Is every foothold gone, and can the user work safely again?	7
Lessons learned	Which control would have stopped this, and is it now in place?	7

1.4 Severity

Severity decides who is paged, how fast containment must start, and whether legal and privacy are involved from the start.

Severity	Typical indicators	Response target
Sev 1 · Critical	Admin account; payment fraud attempted or completed; data exfiltration confirmed; many accounts	Contain within 30 min, incident manager + legal engaged
Sev 2 · High	Confirmed takeover of a standard user; malicious rules or forwarding found; internal phishing sent	Contain within 1 hour
Sev 3 · Medium	High-risk sign-in with no post-compromise activity yet; MFA prompt fatigue reported	Triage within 4 hours
Sev 4 · Low	Single risky sign-in already remediated by policy (MFA satisfied from a known device)	Review next business day

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Minimum role	Notes
Read sign-in, audit logs and risky users	Security Reader or Global Reader	Enough for triage and evidence export.
Confirm compromised / dismiss risk	Security Operator	Entra ID Protection actions.
Block sign-in, revoke sessions, reset password	User Administrator (Privileged Authentication Admin for admins)	Use PIM; resetting an admin needs a higher role.
Remove MFA methods, issue Temporary Access Pass	Authentication Administrator (Privileged Authentication Admin for admins)	
Inbox rules, forwarding, mailbox permissions	Exchange Recipient Administrator	Or Exchange Administrator.
Search the Unified Audit Log	Audit Reader (Purview) or View-Only Audit Logs	Role group in Microsoft Purview.
Revoke OAuth grants, disable enterprise apps	Cloud Application Administrator	Application Administrator also works.
Isolate a device, run AIR	Security Operator (Defender XDR)	Device isolation needs Defender for Endpoint.
Tenant Allow/Block List entries	Security Administrator	Defender for Office 365 / EOP.

2.2 Licensing and data you need

- **Entra ID P2** for Identity Protection risk detections and *Confirm user compromised*. Without it, triage starts from sign-in logs and user reports.
- **Microsoft Purview Audit** enabled (on by default). `MailItemsAccessed` is the record that proves which messages were read; confirm it is being logged for your licences before you need it.
- **Microsoft Defender XDR** (Defender for Office 365 Plan 2, Defender for Endpoint) for incident correlation, advanced hunting and automated investigation.
- **Sentinel or Log Analytics** with Entra sign-in and audit logs and Office 365 activity streamed in (see SOP-AZ-107), retained at least 90 days.

2.3 Prerequisites checklist

- [ ] Incident ticket opened, severity assigned, incident manager named. All actions below are logged in that ticket with time and operator.
- [ ] PowerShell modules installed on a clean admin workstation: `Microsoft.Graph`, `ExchangeOnlineManagement` v3.
- [ ] Evidence location prepared: access-restricted folder or case in Microsoft Purview eDiscovery, with hashes recorded on export.
- [ ] Out-of-band contact for the user (phone, manager) — do not use the possibly compromised mailbox to talk to them.
- [ ] Legal / privacy contact identified for Sev 1–2 incidents.
- [ ] Emergency access accounts and Conditional Access baseline in place (SOP-ID-001), so that containment cannot lock out responders.

2.4 Risk and planning notes

Action	Risk	Notes
Export logs and rules	READ-ONLY	Always first.
Block sign-in + revoke sessions	LOW	User loses access immediately; tell them out of band.
Reset password	LOW	Hybrid users: reset in on-premises AD (or via writeback) so sync does not undo it.
Remove inbox rules / forwarding	MODERATE	Export first; removing before export destroys evidence.
Remove MFA methods	MODERATE	User needs a Temporary Access Pass to re-register.
Disable an enterprise app tenant-wide	HIGH	Affects every user of that app. Revoke the user's grant first; disable the app only if malicious.
Isolate a device	MODERATE	Cuts the device off the network except Defender; coordinate with the user.
Wipe a device	HIGH	Not part of containment. Requires approval under SOP-EM-003.

CHAPTER 3

Detect and Triage

Alerts arrive from several places. Triage turns any of them into the same three answers: *which account*, *is it real*, *what severity*.

3.1 Detection sources

Source	What it shows	Where
Entra ID Protection	Risky users, risky sign-ins: anomalous token, AiTM, unfamiliar sign-in properties, impossible travel, leaked credentials	Entra admin center › ID Protection › Risky users
Defender XDR incidents	Correlated alerts across identity, mail and endpoint, e.g. *BEC financial fraud*, *Suspicious inbox manipulation rule*	security.microsoft.com › Incidents
Defender for Cloud Apps	Impossible travel, activity from infrequent country, suspicious inbox forwarding	Defender portal › Cloud apps alerts
Sentinel analytics	Custom and template rules on SigninLogs, OfficeActivity, AuditLogs	Sentinel › Incidents
User or partner report	"I didn't send that", supplier asks about changed bank details, MFA prompt the user did not start	Service desk / report-phishing button

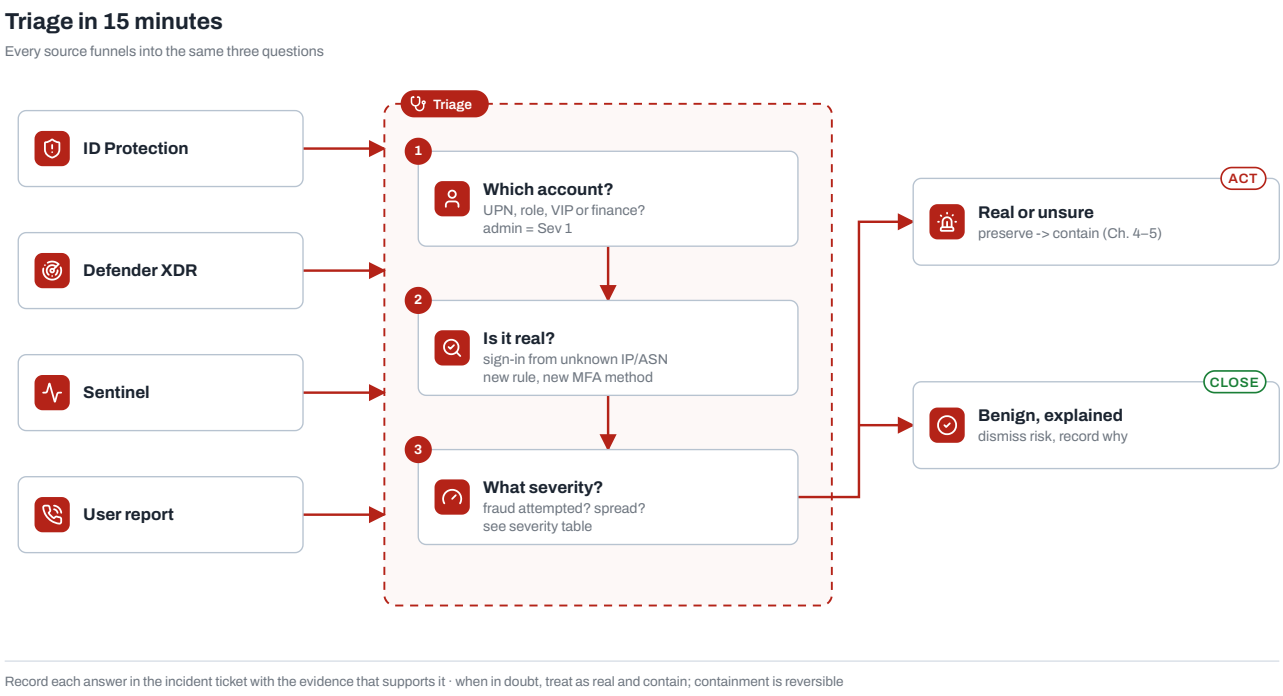


Figure 3. Triage reduces every alert to account, validity and severity. Uncertainty is resolved towards containment.

STEP 1 Triage the alert

1. Open the alert or incident and note the **UPN**, first suspicious time, source IP address and country, and the app signed in to.
2. In Entra ID › Monitoring & health › Sign-in logs, filter by the user for the last 7 days. Compare IP, location, device and browser with the user's normal pattern. Note any sign-in with *Authentication requirement* satisfied by *Previously satisfied* from a new location — a sign of token replay.
3. In Entra ID › Audit logs, filter *Target* = the user. Look for *User registered security info*, *Update user*, *Consent to application* in the same window.
4. Ask the user, by phone, three questions: did you travel or use a VPN, did you approve an MFA prompt you did not start, did you enter your password on a page after clicking a link?
5. Assign severity, record the decision and evidence in the ticket. If the account holds any admin role, escalate to Sev 1 immediately.

WATCH OUT · DO NOT TIP OFF THE ATTACKER BY EMAIL

Never email the user about the investigation: the attacker may be reading the mailbox and can delete the warning or reply as the user. Use phone or Teams on a known-good device, or speak to their manager.

CHAPTER 4

Preserve Evidence First

Containment changes the evidence: removing an inbox rule deletes its definition, resetting MFA removes the method the attacker added. Capture first; it takes ten minutes and cannot be done afterwards.

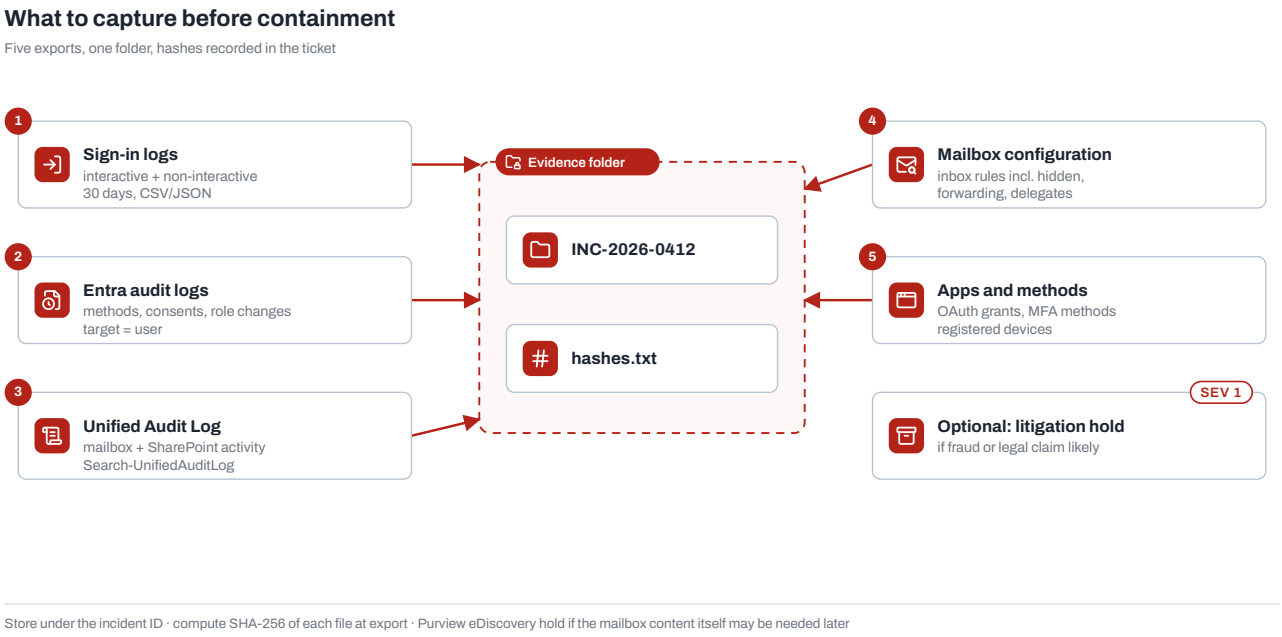


Figure 4. Evidence capture. Everything goes to one restricted location before the first containment step.

4.1 Connect

CONNECT TO GRAPH AND EXCHANGE ONLINE — POWERSHELL

```powershell
Connect-MgGraph -Scopes "User.ReadWrite.All","UserAuthenticationMethod.ReadWrite.All",`
  "AuditLog.Read.All","Directory.Read.All","IdentityRiskyUser.ReadWrite.All",`
  "DelegatedPermissionGrant.ReadWrite.All" -NoWelcome
Connect-ExchangeOnline -ShowBanner:$false
$upn = "jdoe@contoso.com"
$case = "C:\IR\INC-2026-0412"; New-Item $case -ItemType Directory -Force | Out-Null
```

4.2 Export mailbox configuration

INBOX RULES, FORWARDING AND PERMISSIONS — POWERSHELL

```powershell
Get-InboxRule -Mailbox $upn -IncludeHidden |
  Select-Object Name,Enabled,Priority,From,SubjectContainsWords,BodyContainsWords,
    MoveToFolder,DeleteMessage,ForwardTo,RedirectTo,ForwardAsAttachmentTo,MarkAsRead,Description |
  Export-Clixml "$case\inboxrules.xml"
Get-Mailbox $upn | Select-Object ForwardingAddress,ForwardingSmtpAddress,
  DeliverToMailboxAndForward,GrantSendOnBehalfTo | Export-Clixml "$case\forwarding.xml"
Get-MailboxPermission $upn | Where-Object { -not $_.IsInherited } | Export-Clixml "$case\mbxperms.xml"
Get-RecipientPermission $upn | Export-Clixml "$case\sendas.xml"
Get-MailboxFolderPermission "${upn}:\Calendar" | Export-Clixml "$case\calendar.xml"
```

4.3 Export identity evidence

METHODS, GRANTS, DEVICES, SIGN-INS — POWERSHELL

```powershell
$u = Get-MgUser -UserId $upn
Get-MgUserAuthenticationMethod -UserId $u.Id | ConvertTo-Json -Depth 5 | Out-File "$case\authmethods.json"
Get-MgUserOauth2PermissionGrant -UserId $u.Id -All | ConvertTo-Json -Depth 5 | Out-File
"$case\oauthgrants.json"
Get-MgUserRegisteredDevice -UserId $u.Id | ConvertTo-Json -Depth 5 | Out-File "$case\devices.json"
Get-MgAuditLogSignIn -Filter "userId eq '$($u.Id)'" -Top 1000 |
  ConvertTo-Json -Depth 8 | Out-File "$case\signins.json"
Get-ChildItem $case -File | Get-FileHash -Algorithm SHA256 | Export-Csv "$case\hashes.csv" -NoTypeInformation
```

NOTE · NON-INTERACTIVE SIGN-INS

Token replay shows up mostly in **non-interactive** sign-ins (apps refreshing tokens). In the portal, switch the sign-in logs tab to *User sign-ins (non-interactive)*; in Log Analytics the table is `AADNonInteractiveUserSignInLogs`. Export both.

CHAPTER 5

Contain

Work the list in order. The order matters: the first three steps take the attacker's live access away; the rest remove what they left behind. Steps 1–3 should be complete within minutes of the severity decision.

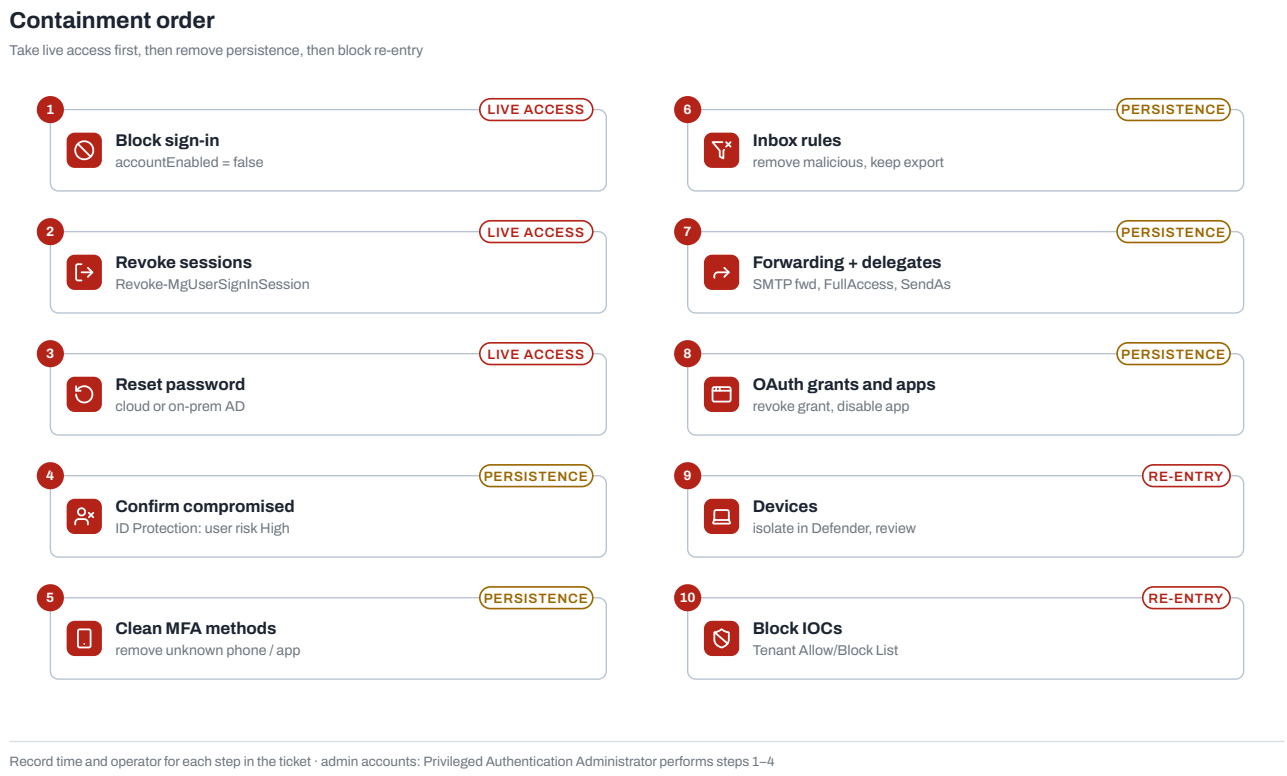


Figure 5. Ten steps in a fixed order. Steps 1–3 stop live access; 4–10 remove persistence and block the attacker's infrastructure.

STEP 1 Take live access away (steps 1–3)

1. In `Entra ID` › `Users` › select the user › `Edit properties` › `Settings` › untick `Account enabled` › `Save`. For a hybrid user, also disable the account in on-premises AD, or sync will re-enable it.
2. On the user's overview page select `Revoke sessions` › `Yes`. This invalidates refresh tokens and session cookies for all apps.
3. Select `Reset password`. Generate a random password and do **not** give it to the user yet. Hybrid: reset in AD (or rely on password writeback) and force a sync cycle.

Block sign-in first so that the attacker cannot sign in again between the revoke and the reset.

STEPS 1–3 IN POWERSHELL POWERSHELL

```powershell
$u = Get-MgUser -UserId $upn
Update-MgUser -UserId $u.Id -AccountEnabled:$false                # 1 block sign-in
Revoke-MgUserSignInSession -UserId $u.Id                          # 2 revoke refresh tokens
$pw = -join ((48..57)+(65..90)+(97..122) | Get-Random -Count 24 | ForEach-Object {[char]$_})
Update-MgUser -UserId $u.Id -PasswordProfile @{                     # 3 reset
  Password = $pw; ForceChangePasswordNextSignIn = $true }
```

STEP 2 Remove persistence (steps 4–8)

1. ID Protection › Risky users › select the user › Confirm user compromised. This sets user risk to High so any risk-based policy (CA008 in SOP-ID-001) applies.
2. Users › user › Authentication methods. Compare with the export: delete any phone number, Authenticator app or other method the user did not register. When unsure, delete all except FIDO2 keys the organisation issued.
3. Remove the malicious inbox rules (code below). Check the mailbox in Outlook on the web for rules visible only there, and check **Sweep** rules.
4. Clear SMTP forwarding, remove unexpected *FullAccess*, *SendAs* and *SendOnBehalf* permissions, and unexpected calendar delegates.
5. Entra ID › Enterprise applications › filter by the user's consents (or use the export). Revoke the user's grant for any unfamiliar app. If the app is malicious, set Enabled for users to sign-in? to **No** and record its App ID as an IOC.

STEPS 4–8 IN POWERSHELL POWERSHELL

```powershell
Confirm-MgRiskyUserCompromised -UserIds $u.Id                                    # 4
Get-MgUserAuthenticationPhoneMethod -UserId $u.Id                                 # 5 review, then:
# Remove-MgUserAuthenticationPhoneMethod -UserId $u.Id -PhoneAuthenticationMethodId <id>
# Remove-MgUserAuthenticationMicrosoftAuthenticatorMethod -UserId $u.Id -
MicrosoftAuthenticatorAuthenticationMethodId <id>

Get-InboxRule -Mailbox $upn -IncludeHidden | Format-Table Name,Enabled,MoveToFolder,ForwardTo,DeleteMessage
Remove-InboxRule -Mailbox $upn -Identity "<rule name>" -Confirm:$false            # 6 per malicious rule

Set-Mailbox $upn -ForwardingSmtpAddress $null -ForwardingAddress $null `
  -DeliverToMailboxAndForward $false                                             # 7
# Remove-MailboxPermission $upn -User <trustee> -AccessRights FullAccess -Confirm:$false
# Remove-RecipientPermission $upn -Trustee <trustee> -AccessRights SendAs -Confirm:$false

Get-MgUserOauth2PermissionGrant -UserId $u.Id -All |
  Format-Table Id,ClientId,Scope                                                 # 8 review, then:
# Remove-MgOauth2PermissionGrant -OAuth2PermissionGrantId <id>
```

STEP 3 **Close the outer doors (steps 9–10)**

1. In the Defender portal, open each device the user signed in from during the incident window. If the endpoint shows malware, an infostealer or suspicious processes, select **Isolate device** (full isolation keeps the Defender connection). Never wipe as part of containment; a wipe needs approval under SOP-EM-003.
2. Block the attacker's infrastructure: **Email & collaboration** › **Policies & rules** › **Threat policies** › **Tenant Allow/Block Lists**. Add the sending domains and phishing URLs; add the attacker IPs to a Conditional Access named location that is blocked.

BLOCK SENDER DOMAIN AND PHISHING URL — POWERSHELL

```
New-TenantAllowBlockListItems -ListType Sender -Block -Entries "invoices-contoso.co" -NoExpiration
New-TenantAllowBlockListItems -ListType Url -Block -Entries "login-contoso.example/*" -NoExpiration
```

GOOD PRACTICE · LET AUTOMATED INVESTIGATION HELP, BUT CHECK ITS WORK

With Defender for Office 365 Plan 2, an automated investigation can be started on a compromised user. It proposes remediation such as removing forwarding rules and soft-deleting malicious mail across mailboxes. Approve actions from the Action center only after they match what you found manually, and record the investigation ID in the ticket.

CHAPTER 6

Investigate and Scope

Containment answers "can they still get in?". Investigation answers "what did they do while they were in?" and "who else?". Both matter for the closure decision and for any notification duty.

6.1 Build the timeline

Start from the first suspicious sign-in and work forward. Five questions, each with its own evidence source:

Question	Evidence	Where
How did they get in?	Phishing mail, AiTM sign-in, password spray, leaked credential	EmailEvents, SigninLogs, ID Protection detections
What did they change?	New MFA method, consent, rules, forwarding, delegates	AuditLogs, OfficeActivity
What did they read?	Messages and items accessed	`MailItemsAccessed` in the Unified Audit Log
What did they send?	Mail sent as the user, to whom, with which links	EmailEvents, message trace
What else did they touch?	SharePoint / OneDrive downloads, Teams messages	OfficeActivity, CloudAppEvents

6.2 Query the Unified Audit Log

MAILBOX ACTIVITY FOR THE INCIDENT WINDOW — POWERSHELL

```
$start = (Get-Date).AddDays(-14); $end = Get-Date
Search-UnifiedAuditLog -StartDate $start -EndDate $end -UserIds $upn `
  -Operations New-InboxRule,Set-InboxRule,UpdateInboxRules,Set-Mailbox,
              Add-MailboxPermission,Send,SendAs,MailItemsAccessed,FileDownloaded `
  -ResultSize 5000 -SessionCommand ReturnLargeSet |
  Select-Object CreationDate,Operations,ClientIP,AuditData |
  Export-Csv "$case\ual.csv" -NoTypeInformation
```

NOTE · READING MAILITEMSACCESSED

Each record covers a batch of messages, identified by `InternetMessageId` in `AuditData`, with a `ClientIPAddress` and `SessionId`. Filter by the attacker's IPs or session to list what they read. *Bind* operations mean individual messages were opened; *Sync* means a whole folder was synchronised, which must be treated as "all items in that folder were accessed".

6.3 Hunting queries

SIGN-INS FROM THE ATTACKER IPS TO ANY USER (SCOPE) KQL

```
let badIPs = dynamic(["203.0.113.24","198.51.100.77"]);
union SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(14d)
| where IPAddress in (badIPs)
| summarize First = min(TimeGenerated), Last = max(TimeGenerated),
            Apps = make_set(AppDisplayName, 10), Results = make_set(ResultType)
          by UserPrincipalName, IPAddress
| order by First asc
```

INBOX RULES CREATED OR CHANGED TENANT-WIDE KQL

```
OfficeActivity
| where TimeGenerated > ago(14d)
| where Operation in ("New-InboxRule","Set-InboxRule","UpdateInboxRules")
| extend Params = tostring(Parameters)
| where Params has_any ("ForwardTo","RedirectTo","DeleteMessage","MoveToFolder")
| project TimeGenerated, UserId, Operation, ClientIP, Params
| order by TimeGenerated desc
```

WHO ELSE CLICKED THE SAME PHISHING URL (DEFENDER ADVANCED HUNTING) KQL

```
UrlClickEvents
| where Timestamp > ago(14d)
| where Url has "login-contoso.example"
| summarize Clicks = count(), FirstClick = min(Timestamp) by AccountUpn, ActionType
```

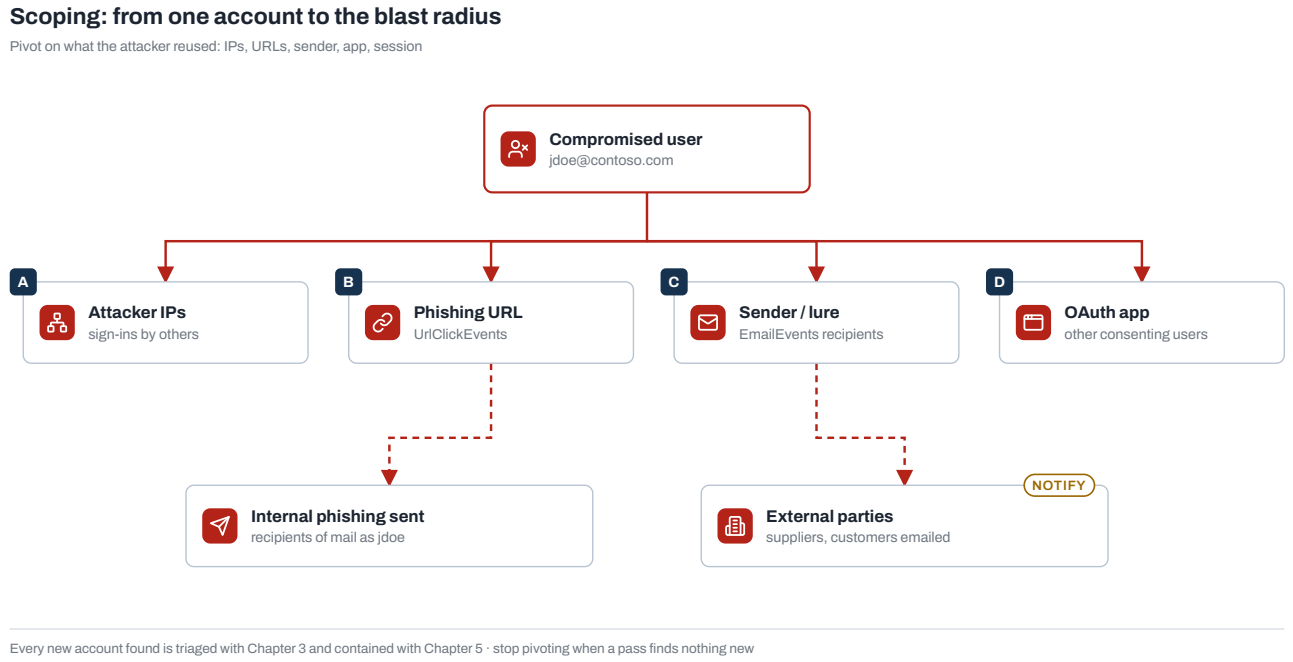


Figure 6. Four pivots from the first account. Each one can reveal more victims, and each victim restarts the triage loop.

CHAPTER 7

Eradicate, Recover and Communicate

7.1 Eradication checklist

- [ ] No sign-ins from attacker IPs or ASNs to any account for 24 hours after containment.
- [ ] No remaining inbox rules, forwarding or delegates that the user does not recognise (re-run the exports and diff).
- [ ] All malicious OAuth grants revoked; malicious apps disabled and listed as IOCs.
- [ ] Phishing mail removed from all mailboxes (Threat Explorer › select messages › `Soft delete`, or Defender AIR action).
- [ ] Affected devices cleared by Defender (no active alerts) or reimaged.
- [ ] Every additional account found in scoping contained and listed in the ticket.

STEP 1 **Recover the user**

1. Meet the user (in person or verified video call). Confirm identity against HR records before issuing anything.
2. Issue a **Temporary Access Pass** (one-time use, short lifetime) through `Users` › user › `Authentication methods` › `Add authentication method`.
3. Re-enable the account (`Account enabled`) and have the user register a **phishing-resistant** method (passkey in Microsoft Authenticator, FIDO2 key or Windows Hello for Business) using the TAP, then set a new password.
4. In ID Protection, the risk state shows *Remediated* after a secure password change; otherwise `Dismiss user risk` with a note referencing the ticket.
5. Add the user to a 30-day watch: a Sentinel watchlist or alert on any sign-in from a new country or ASN, new inbox rule, or new MFA method.

WHY · WHY PHISHING-RESISTANT ON RECOVERY

The attacker beat push or SMS MFA once by relaying it. A passkey or FIDO2 key is bound to the real sign-in domain, so the same AiTM kit cannot relay it. Recovery is the moment the user is most willing to change methods; use it.

7.2 Communication and escalation

Audience	When	Content
User and manager	At containment	What happened, what they will notice, how they get access back. Phone or in person.

Audience	When	Content
Finance / accounts payable	Immediately if payment or bank-detail mail was involved	Hold pending changes; verify by phone using numbers on file.
Recipients of internal phishing	After scoping	Do not open, report if clicked. Sent from IT, not from the compromised mailbox.
External parties emailed by the attacker	Sev 1–2, via legal / account owner	Warning about fraudulent requests; verification channel.
Legal, privacy, compliance	At Sev 1–2 declaration	Data read (MailItemsAccessed), personal data involved, contractual and regulatory notice duties.

WATCH OUT · NOTIFICATION CLOCKS

Data protection laws, sector regulators and contracts can impose notification deadlines measured in days or even hours from when a breach is discovered. Whether they apply is a legal decision; the responder's job is to give legal the facts early: whose mailbox, what was accessed, when it was discovered.

7.3 Lessons learned

Hold a short blameless review within five business days for Sev 1–2. Record: root cause, time to detect, time to contain, what worked, what slowed you down, and one control change with an owner and date. Typical outcomes:

- Phishing-resistant MFA required for the affected group (CA004 pattern in SOP-ID-001, extended to finance).
- User consent to unverified apps turned off; admin consent workflow enabled.
- External auto-forwarding blocked by outbound spam policy.
- Alert on new inbox rules with forward or delete actions (SOP-AZ-107).

CHAPTER 8

Verification, Rollback and Troubleshooting

8.1 Verification checklist

Check	How	Expected
Account blocked during containment	`(Get-MgUser -UserId $upn -Property AccountEnabled).AccountEnabled`	`False` until recovery
Sessions revoked	Sign-in logs after revoke time	Non-interactive sign-ins fail with 50173 / 70043 / similar token errors
No malicious rules	`Get-InboxRule -Mailbox $upn -IncludeHidden`	Only rules the user confirms
No forwarding	`Get-Mailbox $upn | fl Forwarding*`	Both fields empty
MFA methods clean	Authentication methods blade	Only methods registered at recovery
Risk state	ID Protection › Risky users	*Remediated* or *Dismissed* with ticket reference
Evidence complete	Case folder + hashes.csv	All exports present and hashed

8.2 Rollback

Containment is designed to be reversible. If triage turns out wrong (the "impossible travel" was a new VPN), undo in reverse order and record why.

Action taken	Undo	Note
Block sign-in	Re-enable account	Hybrid: re-enable in AD too.
Password reset	User sets a new password via TAP / SSPR	Do not restore the old password.
Confirm compromised	Dismiss user risk with reason	Feeds back into ID Protection.
Removed rule or forwarding	Recreate from the export only if the user confirms it was theirs	Use `New-InboxRule` with the exported parameters.
Device isolation	Defender › device › **Release from isolation**	Only after the device is cleared.

8.3 Troubleshooting

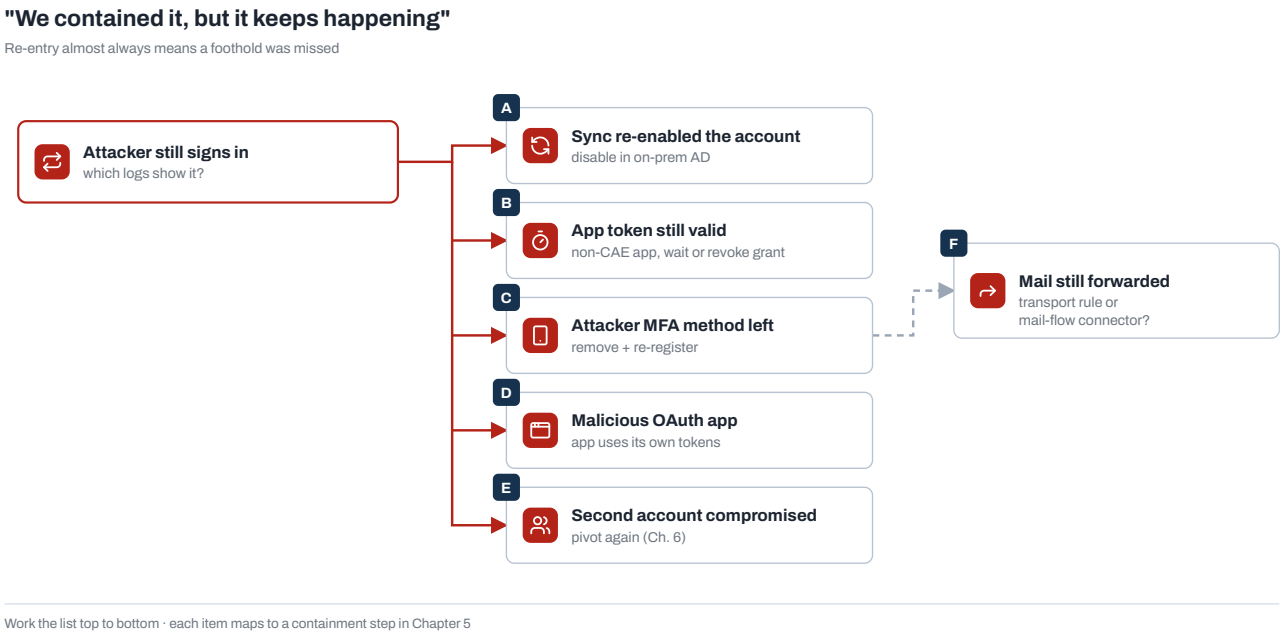


Figure 7. Re-entry after containment. Each letter is a foothold that the fixed containment order is designed to remove.

Symptom	Likely cause	Fix
`Revoke-MgUserSignInSession` **returns 403**	Missing scope or role	Reconnect with `User.ReadWrite.All` (or `User.RevokeSessions.All`) and an activated User Administrator role.
`Get-InboxRule` **shows nothing but mail still disappears**	Rule created via a client and hidden, or a Sweep rule	Use `-IncludeHidden`; check Sweep in Outlook on the web; check `UpdateInboxRules` in the UAL.
Forwarding continues after `Set-Mailbox` **clear**	Forwarding via inbox rule or transport rule	Check rules for ForwardTo/RedirectTo; review mail flow rules (`Get-TransportRule`).
No `MailItemsAccessed` **records**	Auditing for that action not enabled or not licensed	Check `Get-Mailbox $upn | fl AuditEnabled,AuditOwner`; treat the mailbox as fully read if evidence is missing.
User cannot re-register MFA	CA002 requires trusted location or MFA	Issue a Temporary Access Pass; it satisfies the registration policy.

CHAPTER 9

Summary, Glossary and Review

9.1 Chapter summary

- Account takeover is about tokens and persistence, not only the password.
- Triage reduces every alert to account, validity and severity; uncertainty resolves towards containment.
- Preserve evidence before containment: rules, forwarding, methods, grants and logs, hashed in one folder.
- Contain in a fixed order: block sign-in, revoke sessions, reset password, then remove methods, rules, forwarding, delegates and app grants, isolate devices, block IOCs.
- Scope by pivoting on attacker IPs, URLs, senders and apps; every new victim restarts the loop.
- Recover the user on phishing-resistant MFA, watch the account for 30 days, and turn the root cause into one owned control change.

Check your understanding

1. Why does resetting the password not stop an attacker who used an adversary-in-the-middle phishing kit?
2. Give two reasons to export inbox rules before removing them.
3. A hybrid user is re-enabled an hour after you blocked sign-in in Entra ID. What happened and what is the fix?
4. What is the difference between a *Bind* and a *Sync* `MailItemsAccessed` record, and how does it change the notification decision?
5. Name four pivots that help you find other affected accounts.

9.2 Glossary

BEC	Business email compromise: fraud carried out from or by impersonating a legitimate mailbox.
AiTM	Adversary-in-the-middle phishing: a proxy page that relays sign-in and MFA and steals the session.
Refresh token	Long-lived token used to obtain new access tokens; invalidated by session revocation and password reset.
CAE	Continuous Access Evaluation: lets supporting services reject tokens soon after a critical event such as revocation.
Unified Audit Log	Purview audit store of user and admin activity across Microsoft 365.

MailItemsAccessed	Audit action recording mail read by sync or bind operations, with client IP and session.
IOC	Indicator of compromise: IP, domain, URL, hash or app ID tied to the attacker.
Temporary Access Pass	Time-limited passcode that satisfies MFA so a user can register strong methods.
AIR	Automated investigation and response in Microsoft Defender XDR.

9.3 Framework references

Framework	Controls addressed
NIST SP 800-53 Rev. 5	IR-4 Incident Handling · IR-5 Incident Monitoring · IR-6 Incident Reporting · AU-6 Audit Record Review, Analysis and Reporting · SI-4 System Monitoring · AC-2(3) disable accounts
NIST SP 800-61 Rev. 3	Incident response recommendations aligned to CSF 2.0: Detect (DE.AE), Respond (RS.MA, RS.AN, RS.MI), Recover (RC.RP)
CIS Controls v8	17 Incident Response Management · 8 Audit Log Management · 6 Access Control Management
FDA 21 CFR Part 11	§11.10(e) audit trails retained and available for review · §11.300(d) detect and report unauthorized use of identification codes